
MISTTRACK

MistTrack Report

For: DeGame

By: SlowMist

Dated: 2024/03/16

Updated: 2024/03/17

Table of Content

I. Incident Overview: DeGame Official Account Compromised 3

II. Analysis of Theft Incident 4

1. DeGame Potential Compromise on Platform X 4
2. Wallet Compromise After Users Click on Airdrop Links 9

III. Scammer Profile Analysis 11

1. Drainer Used by the Scammer 11
2. Information Related to the Scammer 13

IV. Analysis of Fund Transfer 17

V. Warranties and Disclaimers 19

I. Incident Overview: DeGame Official Account Compromised

On March 14th, the official DeGame X account (@degame_l2y) tweeted about an airdrop, which has since been deleted. The tweet contained a link to the airdrop: https://degame-token.com/airdrop/. A user of DeGame reported losses of approximately 57 PufETH after clicking on the airdrop link.

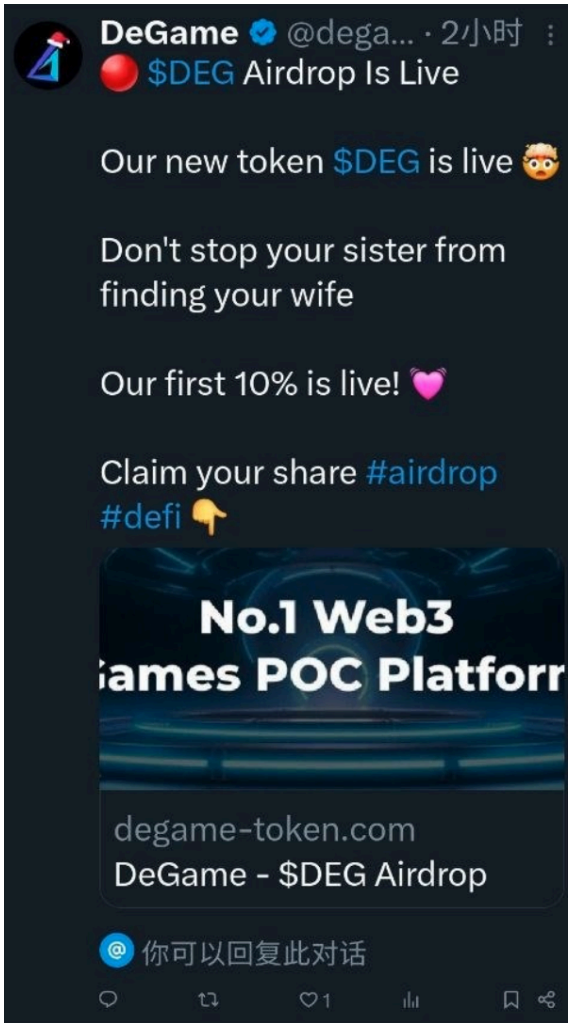


Figure 1 - Screenshot of Airdrop Tweet

The stolen information is summarized in the following Table 1 Summary of Stolen Information:

Chain	Victims Address	Scammers Address	Amount
ETH	0x1298F938B66aDE50628D7b9Df9ACF1BeC3b31aF5	0x9fA7bB759641FCd37fe4aE41f725e0f653f2C726	14.2459 PufETH
ETH	0x1298F938B66aDE50628D7b9Df9ACF1BeC3b31aF5	0xe5621A995c80387A4f87978477BE0DCf85cD3289	42.7378 PufETH
		Total	~57 PufETH

Table 1: Summary of stolen funds

II. Analysis of Theft Incident

1. DeGame Potential Compromise on Platform X

After several days of thorough review and ongoing communication with DeGame, certain suspicions have emerged regarding the dissemination of airdrop tweets: it is suspected that the DeGame account on Platform X was phished and unauthorized access was gained on two occasions.

- On March 1, DeGame received an interview invitation from a fraudulent Cointelegraph reporter using the Platform X account @helodylanjames. This account was later confirmed by the genuine Dylan account @dylanlove to be an impersonator. During the interaction, a link was shared in the direct message conversation that appeared to be a booking site for meetings (calendly.com) through a preview URL. However, upon copying the link, it redirected to a shortened URL on Platform X, https://t.co/5jxhBYK6CD. Further analysis revealed that this URL was, in fact, a phishing link designed to gain unauthorized access to DeGame's Platform X account.

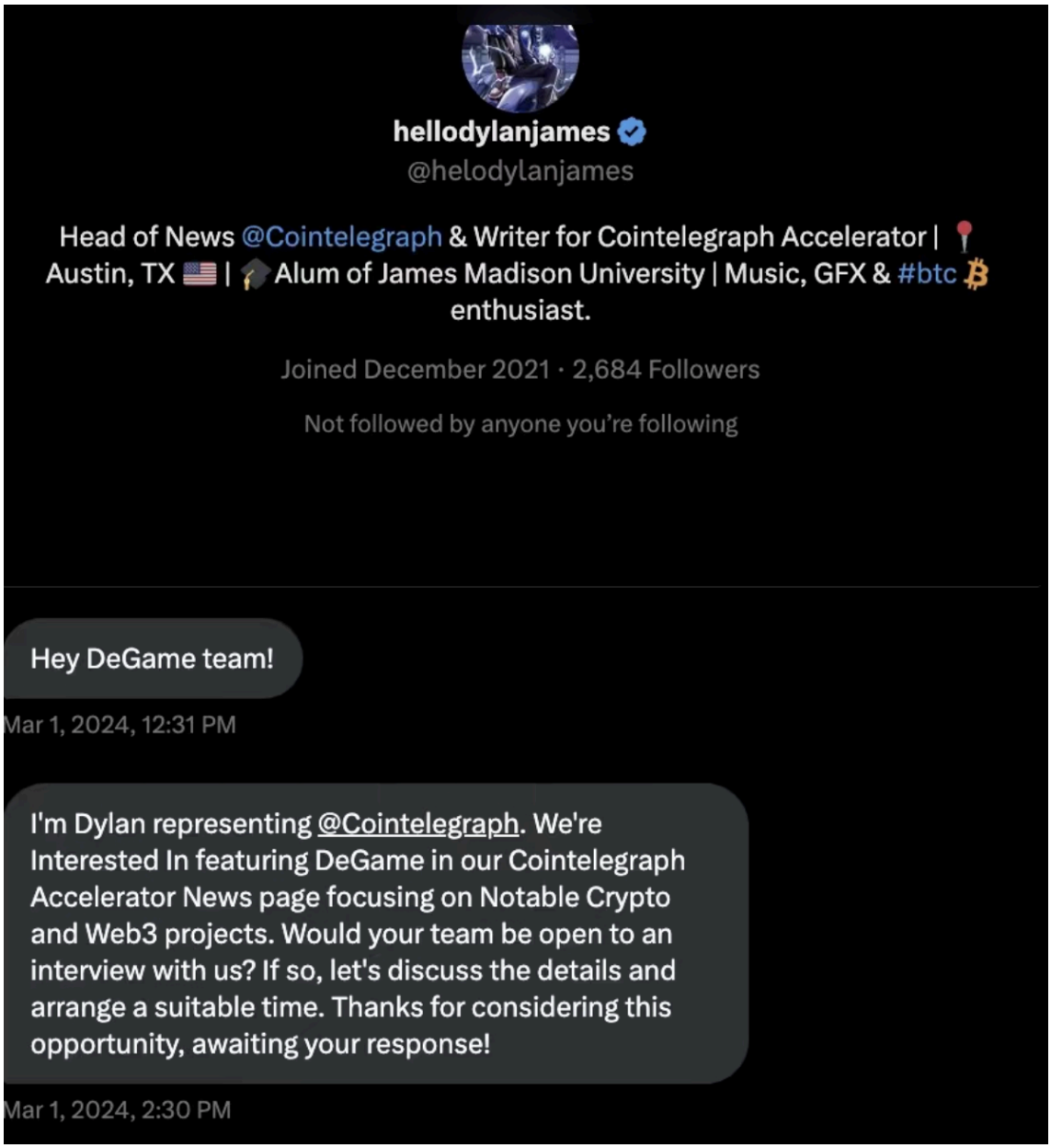


Figure 2 - Message with Fake Cointelegraph Reporter

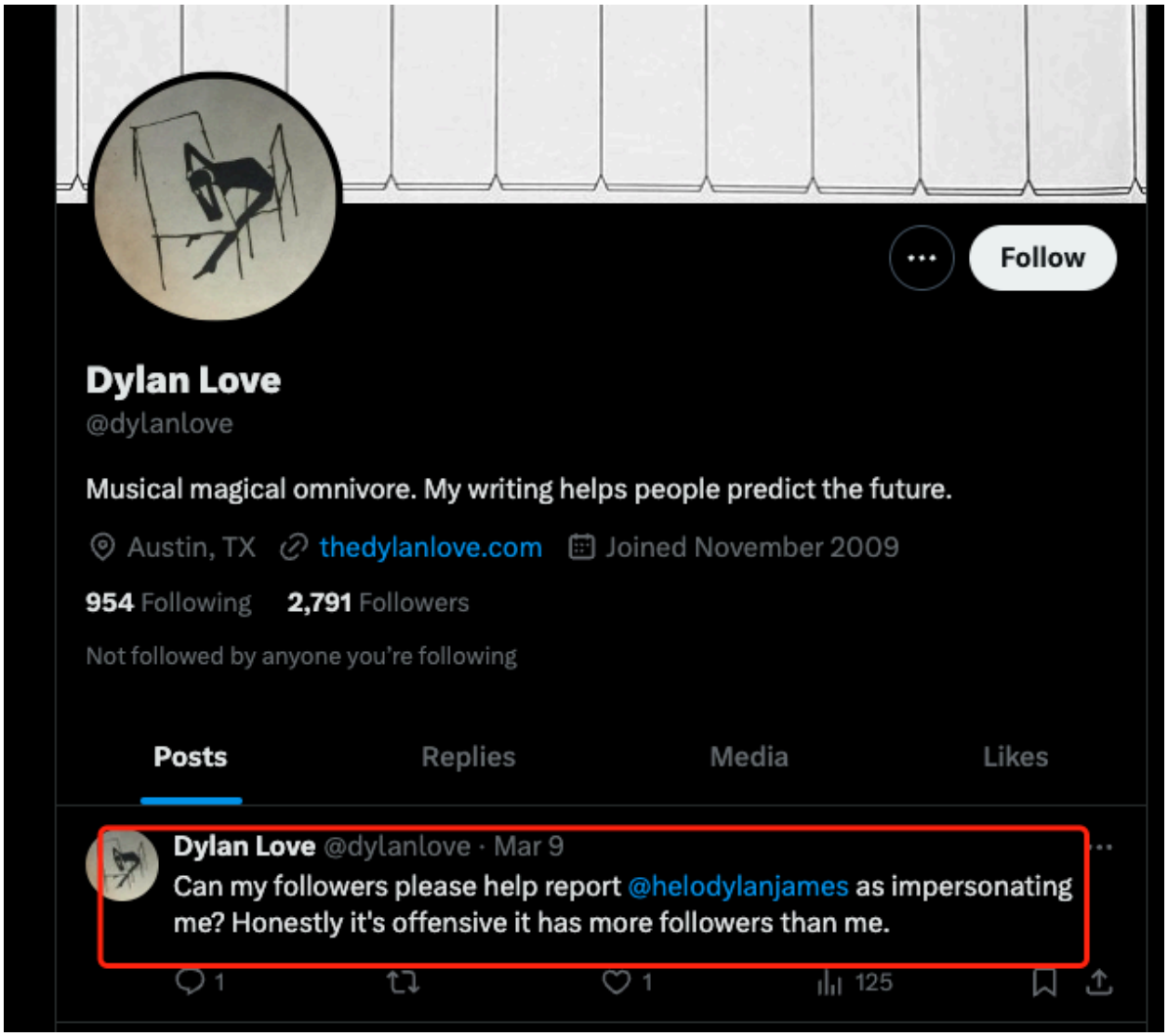


Figure 3 - Tweet by the real Dylan account regarding the fake account

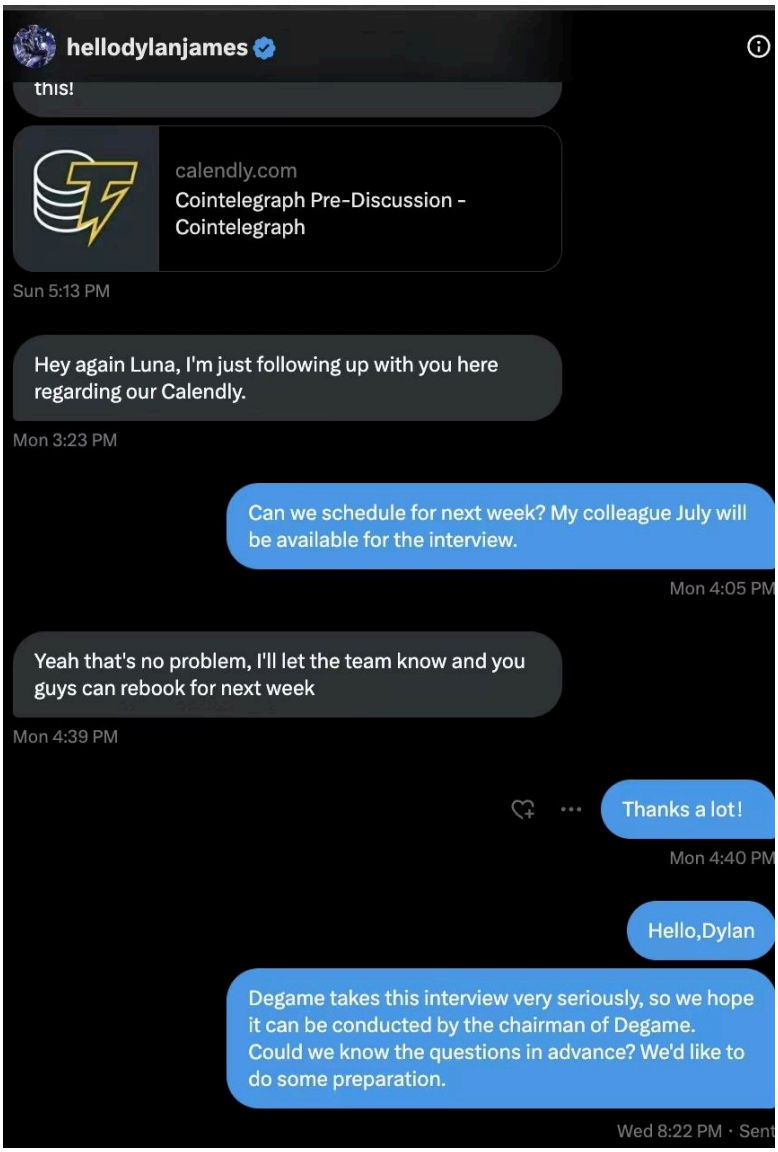


Figure 4 - Suspected fake calendly link sent by the fake Cointelegraph reporter

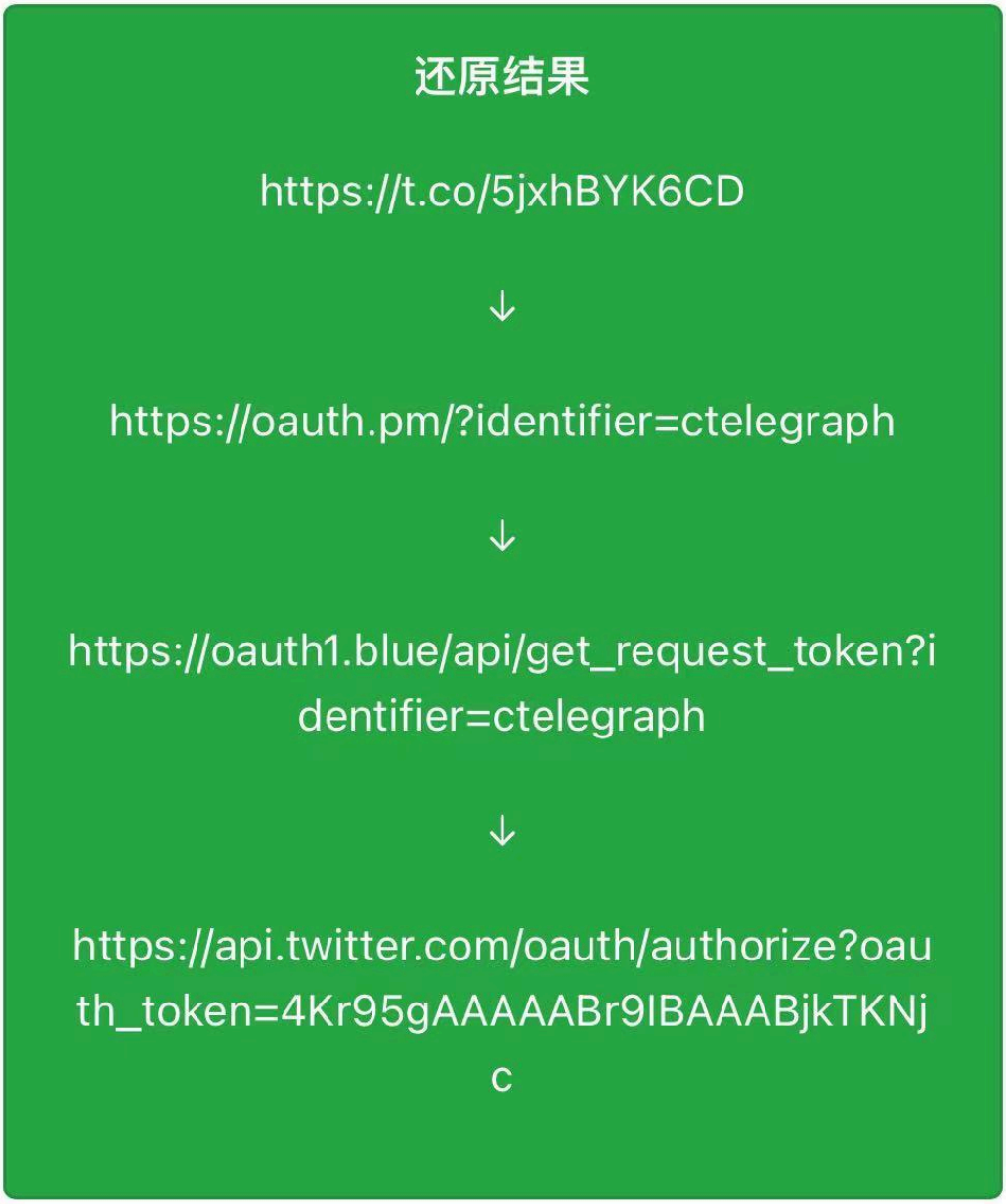


Figure 5 - Results of restoring the X short link URL

- In a recent similar incident, a link was received from individuals impersonating interviewers from The Block media platform, using the URL https://t.co/2VaebXiX2A. After restoring the shortened link, it led to https://theblock.cx/post/311582. Currently, the

site is inaccessible, preventing a full restoration and analysis of the phishing process initiated upon clicking this link.

2. Wallet Compromise After Users Click on Airdrop Links

Upon clicking the aforementioned airdrop link and accessing the website, users are prompted to connect their wallet address. The website then checks for the presence of token balances within the connected wallet address. If a token balance is detected, a transaction signature request for Permit Token Approval pops up.

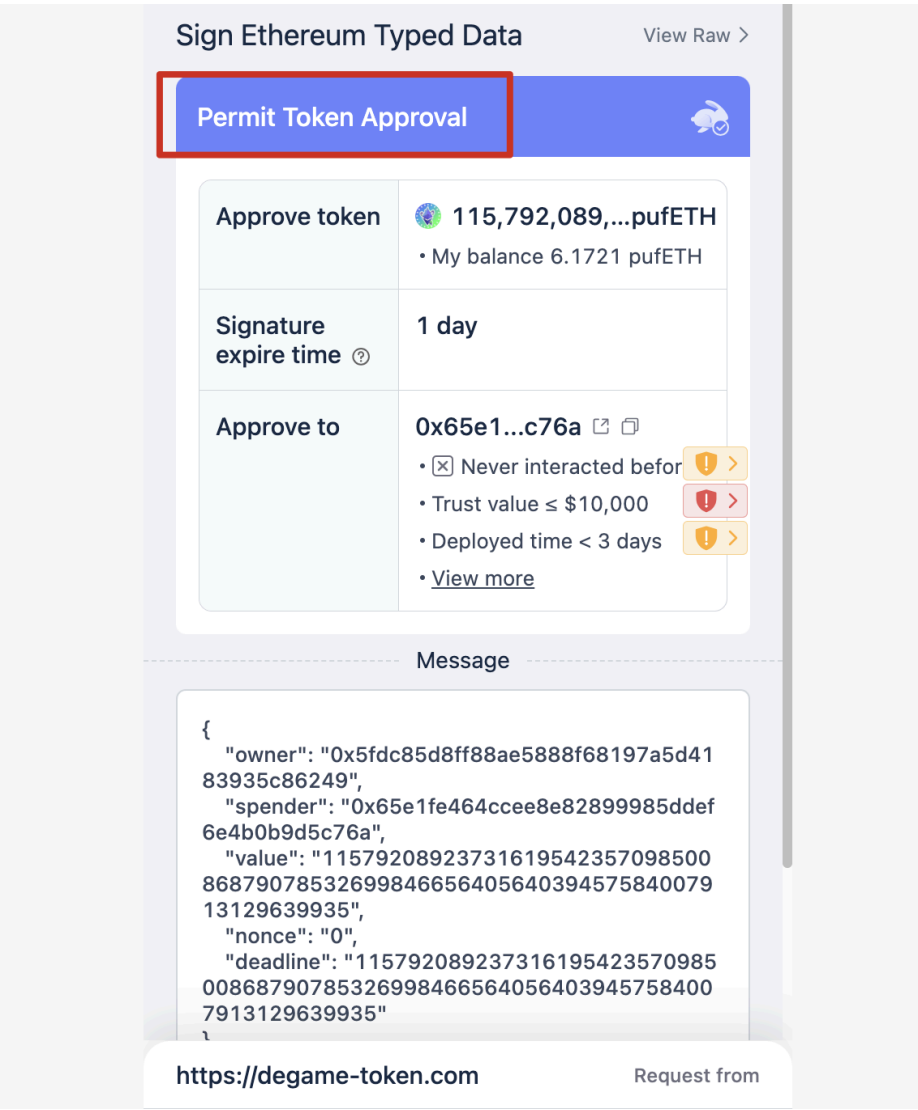


Figure 6 - Permit Token Approval

According to official sources, Permit was introduced into the ERC20 protocol through EIP-2612, allowing users to interact with contracts by attaching an authorization signature (Permit) without prior approval.

This means that after the victims sign, the signature information is uploaded to the phishing site but not recorded on the blockchain. The hackers then submit the Permit on-chain by calling Approve to grant authorization using this signature information.

In this theft incident, the phishing hackers obtained the Permit Token Approval transaction signatures that the victims had authorized for the phishing contract address 0xd560b5325d6669aab86f6d42e156133c534cde90. They then submitted the Permit in the attack transaction, calling Approve to obtain token authorization and transfer the stolen funds.

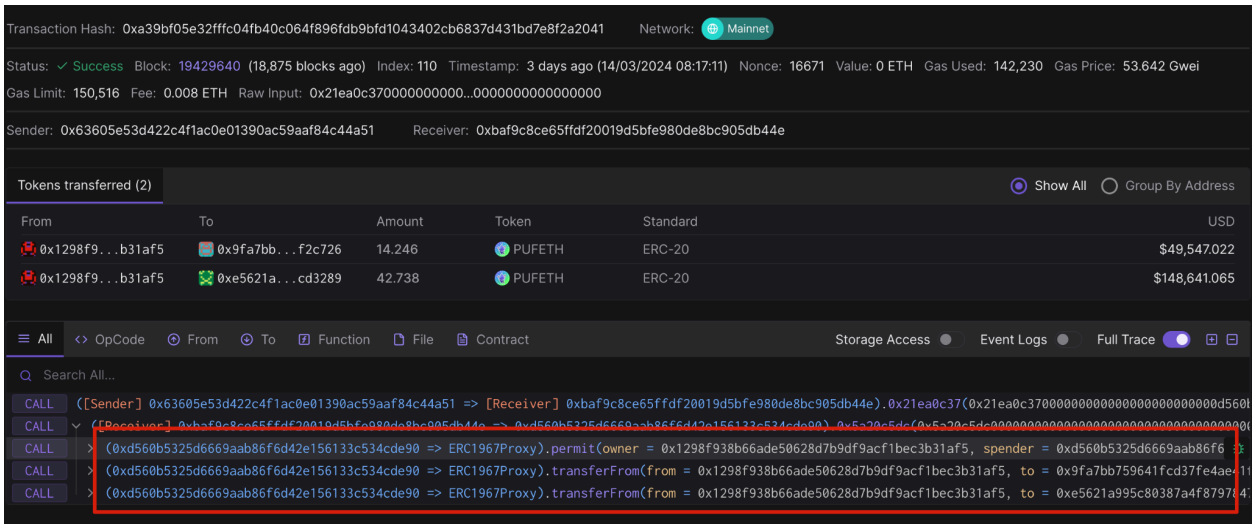


Figure 7 - Details of the Theft Transaction Call Stack

III. Scammer Profile Analysis

1. Drainer Used by the Scammer

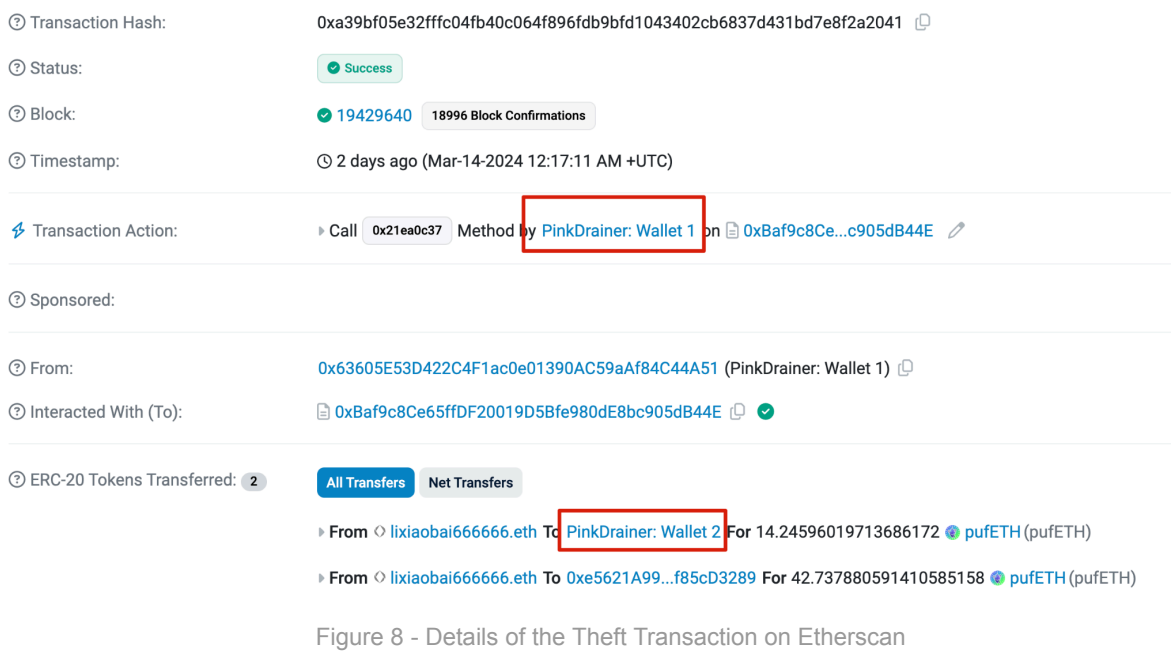


Figure 8 - Details of the Theft Transaction on Etherscan

Based on the blockchain explorer, Etherscan, the address initiating the theft transaction has been flagged as PinkDrainer: Wallet 1, which belongs to the phishing group PinkDrainer as their number 1 wallet address.

Furthermore, about 25% of the stolen funds from this transaction were transferred to PinkDrainer: Wallet 2, another address associated with the PinkDrainer phishing group. Based on intelligence from the SlowMist AML team regarding the PinkDrainer group, it is suspected that the phishing hacker contributes a share to PinkDrainer after utilizing their phishing tools.

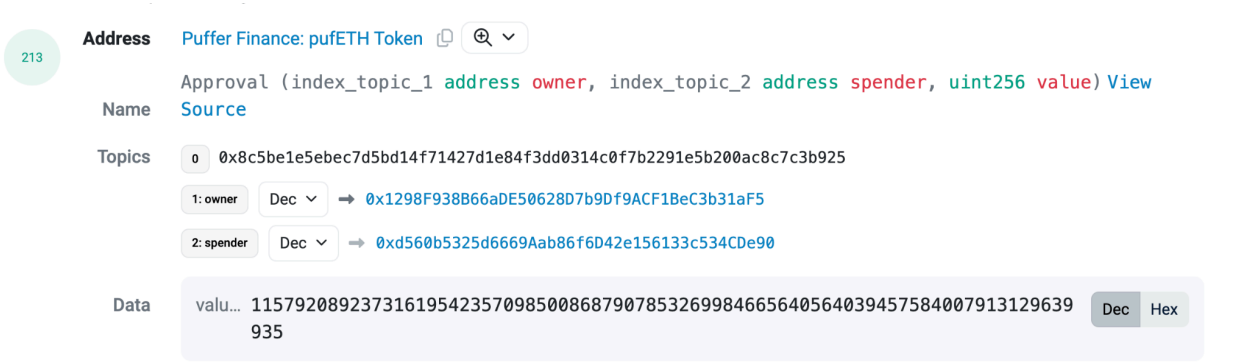


Figure 9 - Details of the Theft Transaction on Etherscan - Event Logs

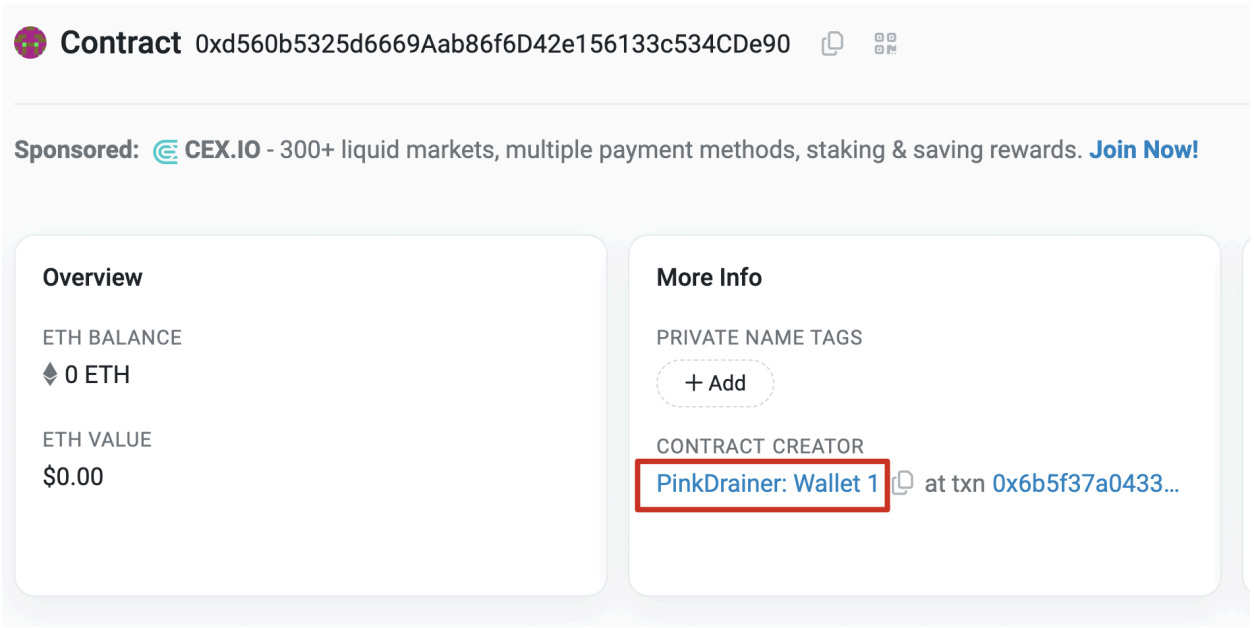


Figure 10 - Phishing Address on Etherscan

The contract creator of the phishing contract address 0xd560b5325d6669aab86f6d42e156133c534cde90, to which the victims authorized, is also PinkDrainer: Wallet 1.

Based on the information above, it can be concluded that in this phishing incident, PinkDrainer served as the tool provider, while the address 0xe5621a995c80387a4f87978477be0dcf85cd3289 was used by the perpetrator to carry out the phishing attack. After successfully phishing, the perpetrator allocated approximately 25% of the illicit gains to PinkDrainer as a fee for providing the tool.

2. Information Related to the Scammer

By utilizing the MistTrack tracking and analysis tool, we were able to perform a detailed analysis related to the scammer responsible for the phishing attack.

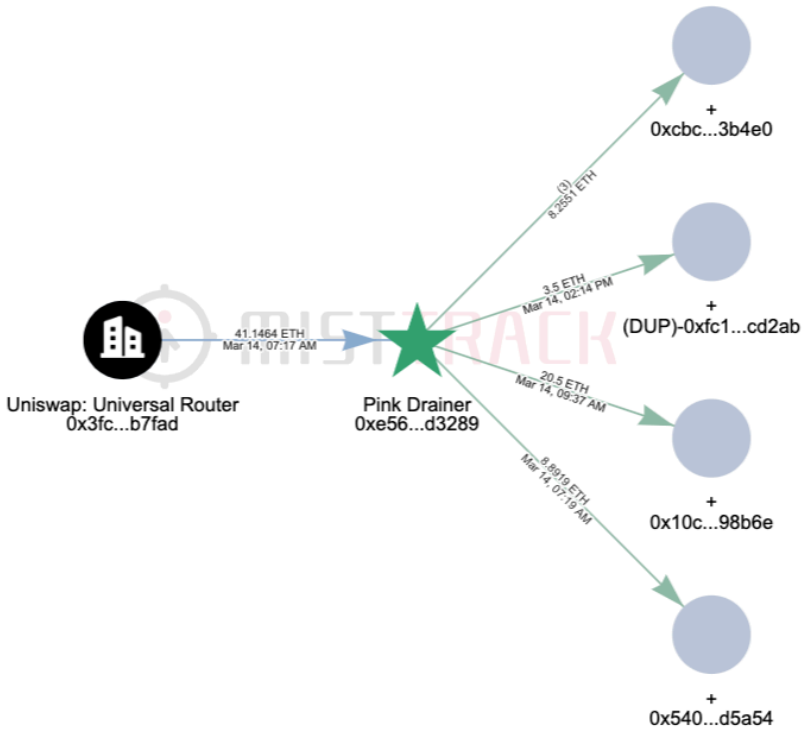


Figure 11 - The Fund Transfer Map of the Phishing Attackers' Addresses

As seen in the diagram above, after exchanging 42.7378 PufETH for 41.1463 ETH through Uniswap, the hackers primarily dispersed the majority of the funds to four different addresses. The second and third addresses from the top are respectively 0xfc17896ff2f07d189a64a7b68dff16f8cc1cd2ab (hereinafter referred to as 0xfc17896f) and 0x10c8f2139cf91a29d92621d4d449056477298b6e (hereinafter referred to as 0x10c8f213).

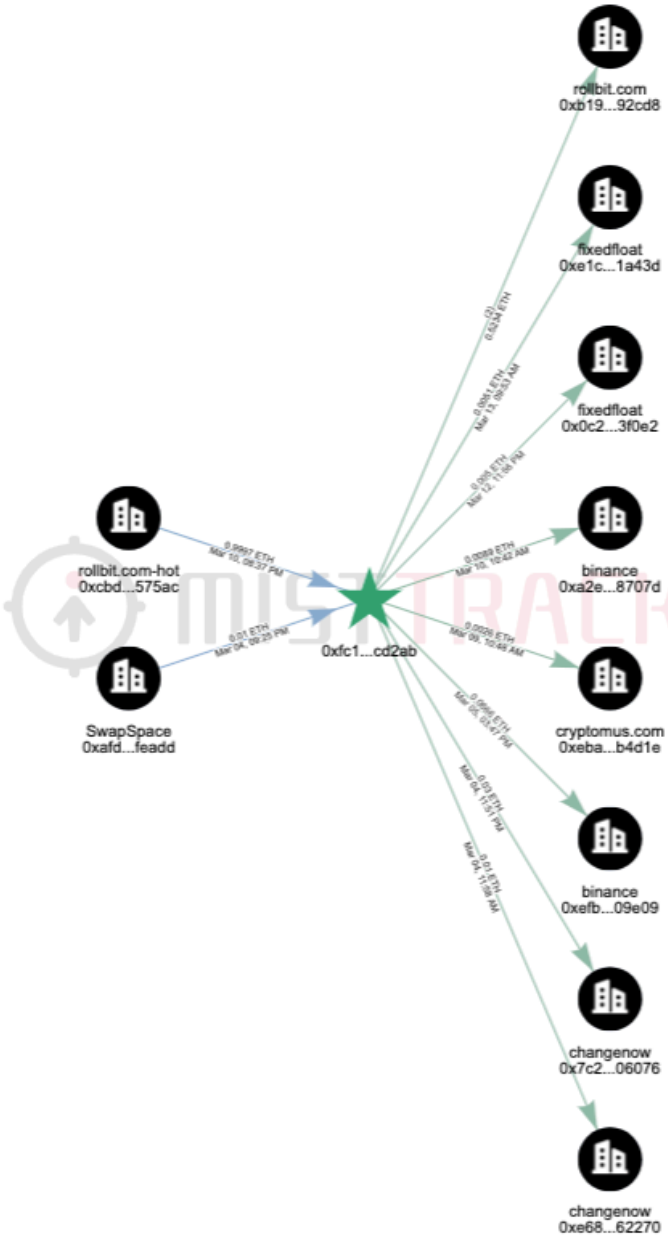


Figure 12 - The Relationship Between Address 0xfc17896f and Exchanges

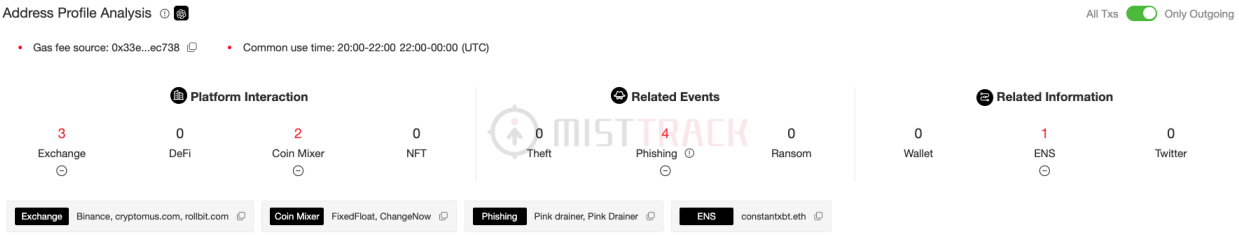


Figure 13 - The Hacker Clue Information Related to Address 0xfc17896f

Based on Figures 12 and 13, it has been discovered that the address 0xfc17896f has a history of transactions with centralized exchanges. According to intelligence held by the SlowMist AML team, the operations IP used by the hackers for interacting with centralized exchanges are mostly VPNs or dynamic IPs located in Europe.

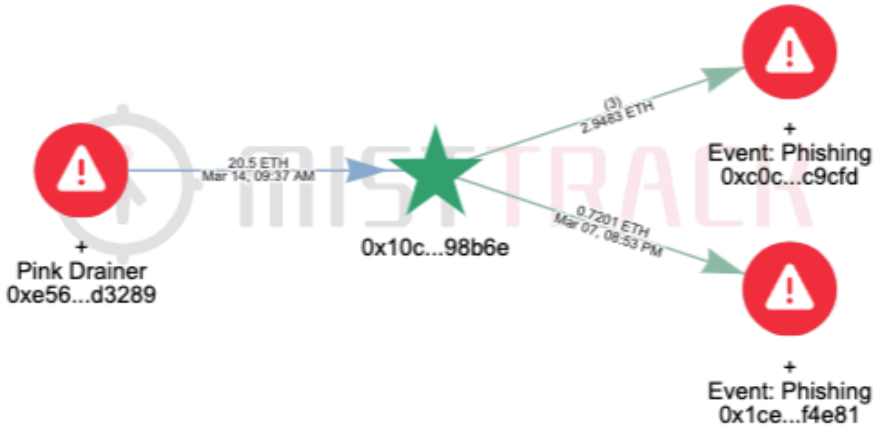


Figure 14 - The Relationship Between Address 0x10c8f213 and Malicious Addresses

According to Figure 14, there is evidence of historical transactions between address 0x10c8f213 and malicious addresses. According to intelligence held by the SlowMist AML team, the outgoing address from 0x10c8f213, 0xc0c6083f5bf4901c503b3fe77109f12618ec9cfd (hereinafter referred to as 0xc0c6083f), has a linkage on the blockchain with hacker addresses related to an NFT Scam event. The specific connections are shown in the following linkage diagram.

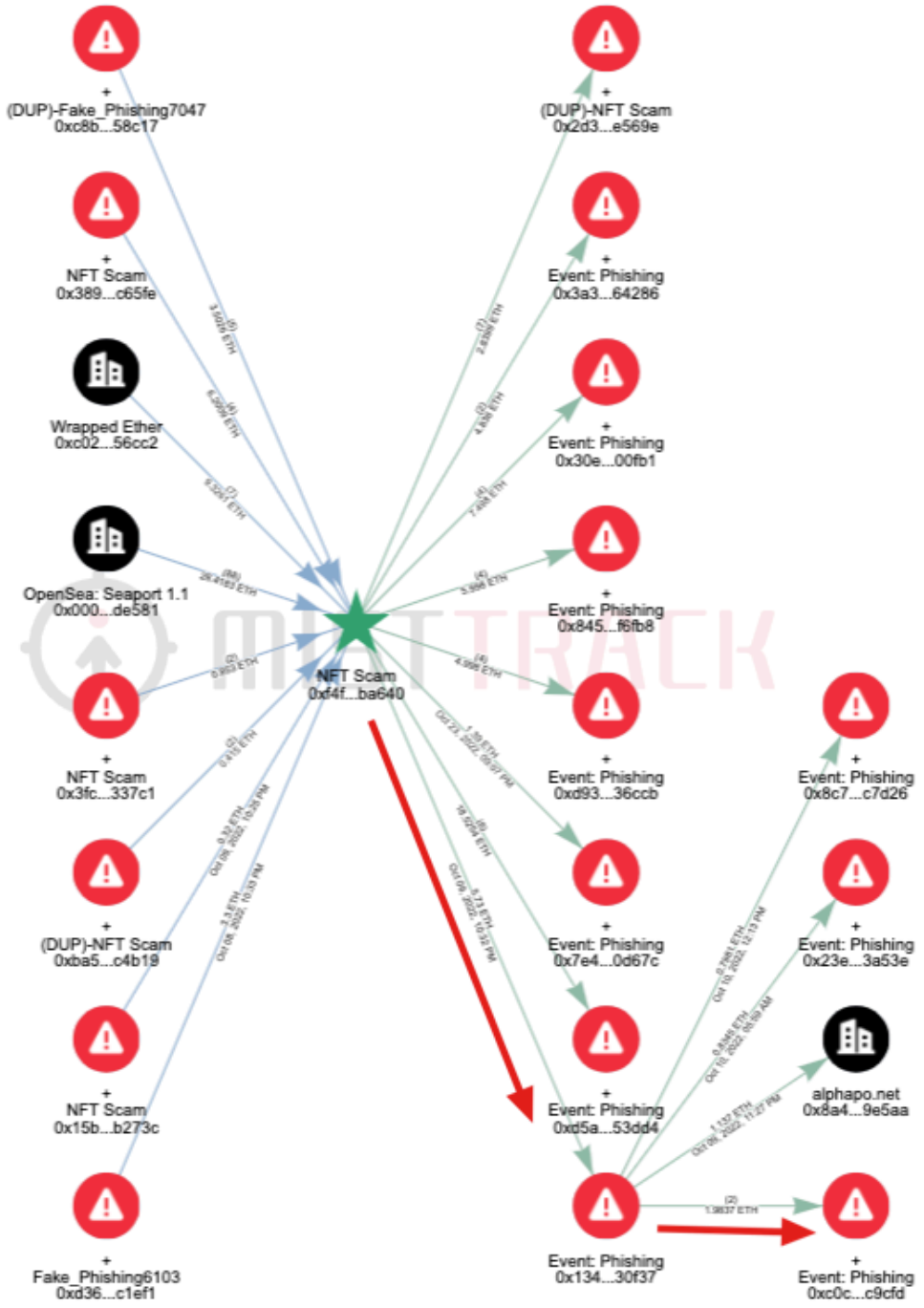


Figure 15 - Relationship Between 0xc0c6083f & 0x10c8f213 and Addresses Related to an NFT Scam Event

IV. Analysis of Fund Transfer

Using our MistTrack tracing and analysis tool, we conducted a detailed analysis of the final destination of the stolen funds, as illustrated in the following Sankey diagram:

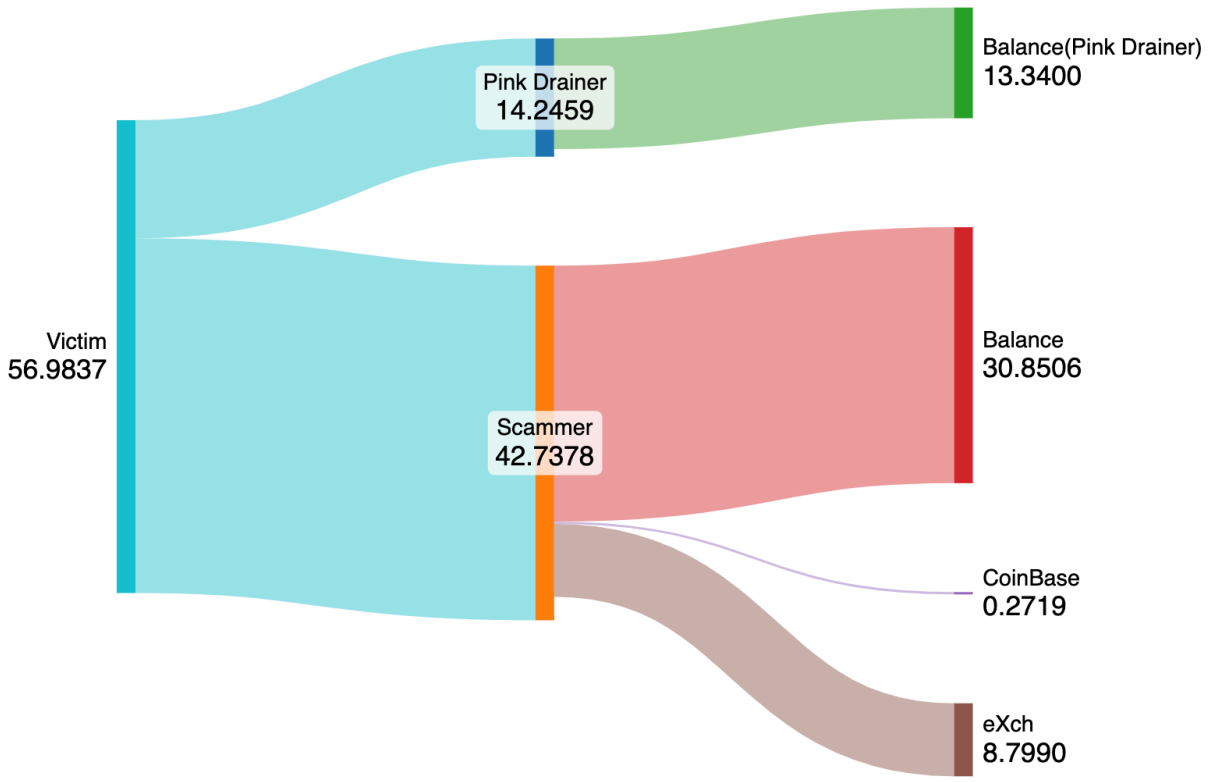


Figure 16 - Sankey Diagram of Stolen Funds Transfer

Excluding intermediary transfers and losses from token exchanges, the details of the stolen funds transfer are as follows in the address table:

*EOA: Externally Owned Accounts

Type	Address	Transferred Stolen Funds (PufETH/ETH)	Balance
EOA	0xA5e4B451D0A3C3D05Fc3A8076fda45952b8	14.2459	4.96M DAI

	f4F83		
EOA	0xbe78430f9c69d3c8c0a5a48d9384703845225 6c0	8.0271	8.0271 ETH
EOA	0xFC17896ff2F07D189a64a7B68dFF16f8cC1C D2ab	3.5	3.5 ETH
EOA	0x10c8f2139cf91a29d92621d4d449056477298 b6e	16.7356	16.7356 ETH
EOA	0xC0C6083f5Bf4901C503b3FE77109f12618eC 9Cfd	2.5879	4.2474 ETH
Exchange	0x1eccdbff2415fb34eefeba0c60149d601530a3 27 (eXch)	8.799	
Exchange	0x9545e6a286c0fc921e8c3008005de89901b37 976 (CoinBase)	0.2719	
	Total	54.1674	

Table 2 - Stolen Funds Transfer Flow Table

V. Warranties and Disclaimers

SlowMist issues this report with reference to the facts that have occurred or existed before the issuance of this report, and only assumes corresponding responsibility based on these.
For the facts that occurred or existed after the issuance, SlowMist is not able to judge the status of this address and is not responsible for them. The address tracking analysis and other contents of this report are based on the documents and materials provided to SlowMist by the information provider till the date of the analysis report (referred to as "provided information").
SlowMist assumes: The information provided is not missing, tampered with, deleted or concealed. If the information provided is missing, tampered with, deleted, concealed, or inconsistent with the actual situation, the SlowMist shall not be liable for any loss or adverse effect resulting therefrom. SlowMist only conducts the agreed analysis on the transaction situation of the address and issues this report. SlowMist is not responsible for the background and other conditions of the client.



Official Website

www.slowmist.com



E-mail

team@slowmist.com



Twitter

@SlowMist_Team



Github

https://github.com/slowmist